

[별표 3]

개인정보관리 전문기관 지정요건 세부기준(제6조 관련)

1. 중계전문기관

구 분		세부기준
1. 설비 및 기술		1) 전송 관리 및 연계, 전송 이력 관리 기능 - 전송요구서 관리, 전자서명 검증, 접근권한 인가 - 이용기관(정보전송자, 일반수신자, 일반전문기관, 특수전문기관) 연계 기능 - 개인정보전송지원플랫폼과의 연계 기능 - 개인정보 전송 이력의 기록·보관 기능 ※ 중계 관련 시스템과 그 외 개인정보처리시스템의 분리 구축 2) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 구성 및 보안시스템 구축 - 중계 관련 시스템의 네트워크 구축 - 중계 관련 시스템에 대한 침입탐지·차단 시스템 구축 3) 중계전문기관 업무의 가용성 및 연속성 보장을 위한 중계 관련 시스템 등의 이중화 구성, 모니터링, 통지 기능 - 중계 관련 시스템 및 네트워크의 이중화 구성 - 중계 관련 시스템 및 네트워크의 상시 모니터링 기능 - 중계 관련 시스템 장애, 오류 등으로 전송 중계 및 전송 지원이 불가능한 경우 보호위원회 및 지정권자, 이용기관(정보전송자, 일반수신자, 일반전문기관, 특수전문기관) 대상 통지 기능
2. 보호체계	가. 보호정책의 수립·시행 및 점검	1) 전문기관 업무 관련 정보의 안전성 확보를 위한 내부 관리계획 ※ 중계 관련 시스템에 대한 정기적인 취약점 점검 및 조치 방안, 해킹 등 전자적 침해행위로부터 보호하기 위한 방안 포함 2) 개인정보 전송 이력의 기록·보관 및 점검 방안
	나. 접근권한의 관리	3) 중계 관련 시스템의 주요 정보를 안전하게 처리하기 위한 접근 권한의 관리 및 점검 체계
	다. 접근통제	4) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 중계 관련 시스템, 업무용 단말

		등에 대한 접근통제 체계 - 중계 관련 시스템에 대한 접속 권한의 제한 등 접근통제 조치 - 중계 관련 시스템에 대한 외부 접속시 안전한 인증수단 등의 적용 5) 유출 및 해킹을 신속하게 탐지·대응할 수 있는 모니터링 체계 - 유출 및 해킹 탐지 시스템, 네트워크 등에 대한 실시간 모니터링, 이상행위 분석·조사 등 조치 6) 중계 관련 시스템에 접근할 수 있는 관리용 단말기를 지정·관리하고, 중계 관련 시스템에 접속하려는 경우 추가적인 인증수단 등 안전한 인증수단을 적용하여 정당한 권한을 가진 자만 접속 가능하도록 조치 7) 중계 관련 시스템에 접근할 수 있는 관리용 단말기에 대한 인터넷망 차단 조치
	라. 암호화	8) 정보의 송·수신 등을 위한 안전한 암호화 적용 9) 암호 키의 안전한 관리 체계 - 안전한 암호 키 생성·이용·배포·보관, 파괴 등에 대한 정책 및 절차의 수립·이행 - 암호·복호화 대상 시스템과 암호키의 분리
	마. 접속기록의 보관 및 점검	10) 중계 관련 시스템을 안전하게 관리하기 위한 접속기록의 보관 및 점검, 이상접속을 탐지하기 위한 조치 - 접속기록이 위·변조 및 도난, 분실되지 않도록 하기 위한 보관 조치 - 자동화된 방식 등을 통한 접속기록의 분석 기능
	바. 악성프로그램 등 방지	11) 악성프로그램 등을 예방·탐지·대응하기 위한 조치 - 보안프로그램의 설치 및 최신 업데이트 관리, 발견된 악성프로그램에 대한 삭제 등 조치
	사. 물리적 안전조치	12) 정보를 안전하게 보관·관리하기 위한 물리적 안전조치
	아. 재해·재난 대비 안전조치	13) 재난·재해 및 장애 등에 대비한 비상계획, 복구 계획 및 훈련실시 방안 - 위기대응 매뉴얼 마련 및 정기적 점검

		14) 중계전문기관 업무 관련 정보의 안전한 백업 및 복구 체계(소산 포함)
	자. 출력복사시 안전조치	15) 개인정보, 전송요구서 등을 안전하게 이용·관리 하기 위한 출력·복사시 안전조치 방안 - 개인정보 출력시(인쇄, 화면표시, 파일생성 등) 용도의 특정 및 출력 항목 최소화
	차. 파기	16) 정보의 안전한 파기를 위한 조치 - 데이터가 복구 또는 재생되지 않도록 파기하는 등 조치
	카. 그 밖에 필요한 조치	17) 중계 관련 시스템의 가용성 및 연속성 보장을 위한 주요 지표 마련 및 관리 방안 18) 중계 관련 시스템 정비 및 프로그램 변경·이행 절차 19) 중계전문기관의 안정적 운영을 위한 전담조직 및 담당인력 지정

※ 그 외 법 제29조에 따른 개인정보의 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

2. 일반전문기관

구 분		세부기준
1. 설비 및 기술		1) 전송 관리 및 연계, 전송 이력 관리 기능 - 전송요구서 관리 및 정보주체 인증 기능 - 중계전문기관과의 연계 기능 - 개인정보전송지원플랫폼과의 연계 기능 - 개인정보 전송 이력의 기록·보관 기능 - 전송받은 정보의 분리·보관 기능 - 전송 내역, 전송받은 정보의 제3자 제공 동의 내역의 중계전문기관을 통한 개인정보전송지원 플랫폼 제출 기능 2) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 구성 및 보안시스템 구축 - 전송 요구 관련 시스템의 네트워크 구축 - 전송 요구 관련 시스템에 대한 침입탐지·차단 시스템 구축
2. 보호체계	가. 보호정책의 수립·시행 및 점검	1) 전문기관 업무 관련 정보의 안전성 확보를 위한 내부 관리계획 ※ 전송 요구 관련 시스템에 대한 정기적인 취약점 점검 및 조치 방안, 해킹 등 전자적 침해행위로부터 보호하기 위한 방안 포함 2) 개인정보 전송 이력의 기록·보관 및 점검 방안 3) 정보주체 대상 전송 내역의 통지 절차
	나. 접근권한의 관리	4) 전송 요구 관련 시스템의 주요 정보를 안전하게 처리하기 위한 접근 권한의 관리 및 점검 체계
	다. 접근통제	5) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 전송 요구 관련 시스템, 업무용 단말 등에 대한 접근통제 체계 - 전송 요구 관련 시스템에 대한 접속 권한의 제한 등 접근통제 조치 - 전송 요구 관련 시스템에 대한 외부 접속시 안전한 인증수단 등의 적용
	라. 암호화	6) 정보의 송·수신 등을 위한 안전한 암호화 적용
	마. 접속기록의	7) 전송 요구 관련 시스템을 안전하게 관리하기 위한

	보관 및 점검	접속기록의 보관 및 점검 체계 - 접속기록이 위·변조 및 도난, 분실되지 않도록 하기 위한 보관 조치
	바. 악성프로그램 등 방지	8) 악성프로그램 등을 예방·탐지·대응하기 위한 조치 - 보안프로그램의 설치 및 최신 업데이트 관리, 발견된 악성프로그램에 대한 삭제 등 조치
	사. 물리적 안전조치	9) 정보를 안전하게 보관·관리하기 위한 물리적 안전조치
	아. 재해·재난 대비 안전조치	10) 재난·재해 및 장애 등에 대비한 비상계획, 복구 계획 및 훈련 실시 방안 - 위기대응 매뉴얼 마련 및 정기적 점검 11) 정보의 안전한 백업 및 복구 체계
	자. 출력·복사시 안전조치	12) 개인정보, 전송요구서 등을 안전하게 이용·관리 하기 위한 출력·복사시 안전조치 방안 - 개인정보 출력시(인쇄, 화면표시, 파일생성 등) 용도의 특정 및 출력 항목 최소화
	차. 파기	13) 정보의 안전한 파기를 위한 조치 - 데이터가 복구 또는 재생되지 않도록 파기하는 등 조치

※ 그 외 법 제29조에 따른 개인정보의 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

3. 특수전문기관

구 분		세부기준
1. 설비 및 기술		1) 전송 관리 및 연계, 전송 이력 관리 기능 - 전송요구서 관리 및 정보주체 인증 기능 - 중계전문기관과의 연계 기능 - 개인정보전송지원플랫폼과의 연계 기능 - 개인정보 전송 이력의 기록·보관 기능 - 전송받은 정보의 분리·보관 기능 - 전송 내역, 전송받은 정보의 제3자 제공 동의 내역의 중계전문기관을 통한 개인정보전송지원 플랫폼 제출 기능 2) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 구성 및 보안시스템 구축 - 전송 요구 관련 시스템의 네트워크 구축 - 전송 요구 관련 시스템에 대한 침입탐지·차단 시스템 구축
2. 보호체계	가. 보호정책의 수립·시행 및 점검	1) 전문기관 업무 관련 정보의 안전성 확보를 위한 내부 관리계획 ※ 전송 요구 관련 시스템에 대한 정기적인 취약점 점검 및 조치 방안, 해킹 등 전자적 침해행위로부터 보호하기 위한 방안 포함 2) 개인정보 전송 이력의 기록·보관 및 점검 방안 3) 정보주체 대상 전송 내역의 통지 절차
	나. 접근권한의 관리	4) 전송 요구 관련 시스템의 주요 정보를 안전하게 처리하기 위한 접근 권한의 관리 및 점검 체계
	다. 접근통제	5) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 전송 요구 관련 시스템, 업무용 단말 등에 대한 접근통제 체계 - 전송 요구 관련 시스템에 대한 접속 권한의 제한 등 접근통제 조치 - 전송 요구 관련 시스템에 대한 외부 접속시 안전한 인증수단 등의 적용 6) 유출 및 해킹을 신속하게 탐지·대응할 수 있는 모니터링 체계 - 유출 및 해킹 탐지 시스템, 네트워크 등에 대한

		실시간 모니터링, 이상행위 분석·조사 등 조치 7) 전송 요구 관련 시스템에 접근할 수 있는 관리용 단말기를 지정·관리하고, 전송 요구 관련 시스템에 접속하려는 경우 추가적인 인증수단 등 안전한 인증수단을 적용하여 정당한 권한을 가진 자만 접속 가능하도록 조치 8) 전송 요구 관련 시스템에 접근할 수 있는 관리용 단말기에 대한 인터넷망 차단 조치
	라. 암호화	9) 정보의 송·수신 등을 위한 안전한 암호화 적용 10) 암호 키의 안전한 관리 체계 - 안전한 암호 키 생성·이용·배포·보관, 파괴 등에 대한 정책 및 절차의 수립·이행 - 암호·복호화 대상 시스템과 암호키의 분리
	마. 접속기록의 보관 및 점검	11) 전송 요구 관련 시스템을 안전하게 관리하기 위한 접속기록의 보관 및 점검, 이상접속을 탐지하기 위한 조치 - 접속기록이 위·변조 및 도난, 분실되지 않도록 하기 위한 보관 조치 - 자동화된 방식 등을 통한 접속기록의 분석 기능
	바. 악성프로그램 등 방지	12) 악성프로그램 등을 예방·탐지·대응하기 위한 조치 - 보안프로그램의 설치 및 최신 업데이트 관리, 발견된 악성프로그램에 대한 삭제 등 조치
	사. 물리적 안전조치	13) 정보를 안전하게 보관·관리하기 위한 물리적 안전조치
	아. 재해·재난 대비 안전조치	14) 재난·재해 및 장애 등에 대비한 비상계획, 복구 계획 및 훈련 실시 방안 - 위기대응 매뉴얼 마련 및 정기적 점검 15) 정보의 안전한 백업 및 복구 체계
	자. 출력복사시 안전조치	16) 개인정보, 전송요구서 등을 안전하게 이용·관리하기 위한 출력·복사시 안전조치 방안 - 개인정보 출력시(인쇄, 화면표시, 파일생성 등) 용도의 특정 및 출력 항목 최소화
	차. 파괴	17) 정보의 안전한 파괴를 위한 조치 - 데이터가 복구 또는 재생되지 않도록 파괴하는

		등 조치
--	--	------

※ 그 외 법 제29조에 따른 개인정보의 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.